

06 BOM Squad

Jonathan Knudsen

jonathan.knudsen@duke.edu

Fall 2019

I think this one is challenging. Start early and ask for help when you need it.

Begin by choosing an open source project. Find a reasonably complex application that uses multiple third-party components. For example, you might choose a softphone, an image editor, or a chat application. Make sure you are able to build the project.

When you've selected your project, post a message on Piazza so no one else uses the same project.

Analyze the source code using Black Duck. Analyze the built project using BDBA. If either tool reports fewer than 10 components, try a different project.

Write up the following items:

1. Tell me the names for your scans in Black Duck and BDBA, so I can take a look at them.
2. Discuss the two sets of results you generated, including discrepancies in naming and versions and discrepancies about component vulnerabilities. If your project has a large number of components, you can limit your analysis to 10 components, but go into detail.
3. Based on the results you generated, how do you feel about the risk level of this project? Be as specific as you can.
4. Write a product security policy for SCA. Be as specific as you can.